

CYBERSECURITY BASICS

Exam Study Guide

Clear explanations, exam traps, memory hooks, and Hungarian notes for difficult parts

Source scope: CyberBasics 0-XII + Cybersecurity Course Exam Preparation Guide

How to use this guide

Read each lecture section once for understanding, then use the exam traps and checkpoint questions to test yourself. The exam is multiple choice, so focus on recognizing examples and choosing the best defense, not only memorizing definitions.

Table of Contents

[How the exam thinks](#)

[0. Course overview and mindset](#)

[1. Cybersecurity foundations](#)

[2. Information gathering](#)

[3. Social engineering](#)

[4. Physical security](#)

[5. Network security](#)

[6. Web application security](#)

[7. Cryptographic fundamentals](#)

[8. Password management and hashes](#)

[9. Mobile and embedded / IoT security](#)

[10. Malware and anti-virus](#)

[11. Software security](#)

[12. AI in cybersecurity](#)

[Final exam review sheets](#)

How the exam thinks

Exam format to remember

The exam is a written Canvas test with 30 multiple-choice questions and one correct answer. Passing starts at 19 correct answers. The last attempt counts, so retaking is useful only if you are likely to improve.

- Expect definition questions: CIA, AAA, vulnerability, risk, CVE/CWE, IDS/IPS, SAST/DAST.
- Expect scenario questions: identify whether a story describes phishing, SQL injection, XSS, tailgating, ransomware, passive recon, etc.
- Expect defense-matching questions: choose parameterized queries for SQL injection, output encoding for XSS, MFA for stolen passwords, segmentation for lateral movement.
- Expect conceptual traps: HTTPS does not mean a site is trustworthy; VPN does not protect against phishing; hashing is not encryption.

Magyar magyarázat

A vizsgán nem az lesz a nehéz, hogy tudod-e a fogalom magyar nevét, hanem hogy felismered-e példából. Ha a kérdésben egy támadási történet van, először azonosítsd: emberi manipuláció, webes inputhiba, hálózati elérés, jelszóprobléma vagy malware? Utána válaszd a hozzá illő védekezést.

0. Course overview and mindset

Source lecture: CyberBasics0 + Exam Guide

Core idea

Cybersecurity is not only about computers. The course frames security as protection of information assets against harm, misuse, unauthorized access, data loss, and service disruption. The big idea is layered defense: technology, people, processes, and policy must work together.

What you must know

- Cybersecurity matters because digital systems control business, healthcare, finance, public infrastructure, education, and personal life.
- The attack surface has grown from classic computers to cloud, mobile, IoT, embedded devices, AI systems, and human workflows.
- The course follows a rough attack-chain logic: learn vocabulary, gather information, manipulate humans, enter physical/digital spaces, exploit networks and web apps, understand crypto/passwords, then study malware, software security, and AI.

Hard parts explained

Cyber Kill Chain: A model for thinking about attack phases: reconnaissance, weaponization, delivery, exploitation, installation, command and control, and actions on objectives. You do not need to worship the model; use it to understand that real attacks are chains, not isolated tricks.

Magyar magyarázat

A Cyber Kill Chain azért hasznos, mert megmutatja: egy támadás ritkán egyetlen lépés. Például OSINT -> phishing -> jelszó megszerzése -> VPN belépés -> belső hálózati mozgás -> adatlopás. A védekezésnek ezért több ponton kell megállítania a támadót.

Exam traps and recognition cues

- A single firewall is not “cybersecurity”; it is only one control.
- Lecture discussions and examples can appear on the exam, not only slide titles.
- Cybersecurity has technical, human, and organizational dimensions.

Checkpoint questions

- Can you recognize this concept from a short real-world scenario?
- Can you name the most direct defense or control?
- Can you distinguish it from the closest similar concept?

1. Cybersecurity foundations

Source lecture: CyberBasicsI

Core idea

This lecture builds the vocabulary you need for the entire course: CIA, authenticity, non-repudiation, risk, threat actors, vulnerabilities, incidents, controls, data states, and AAA.

What you must know

- Confidentiality protects information from unauthorized disclosure.
- Integrity protects information from unauthorized or accidental modification.
- Availability ensures systems and data are accessible to authorized users when needed.
- Authenticity means something is genuinely from the claimed source.
- Non-repudiation makes it hard for an actor to deny an action later.
- Risk is about the combination of threat, vulnerability, likelihood, and impact.
- Security controls reduce risk by preventing, detecting, correcting, or compensating for problems.

Hard parts explained

CIA Triad: The core model for security goals: Confidentiality, Integrity, Availability.

AAA: Authentication asks "Who are you?", Authorization asks "What are you allowed to do?", Accounting records "What did you do?".

Cybersecurity Cube: A way to combine CIA goals, data states, and safeguards: data at rest, in transit, and in process; protected by technology, policy, and people.

Magyar magyarázat

A leggyakoribb keverés: authentication és authorization. Ha beírod a jelszavad, az hitelesítés. Ha a rendszer eldönti, hogy törölhetsz-e egy fájlt, az jogosultságkezelés. A kettő nem ugyanaz.

Exam traps and recognition cues

- If data is leaked, confidentiality is broken.
- If a database record is altered without permission, integrity is broken.
- If a system is down during a DDoS attack, availability is broken.
- A vulnerability is a weakness; an incident is when something actually goes wrong; risk is the expected possibility and impact.

Checkpoint questions

- Can you recognize this concept from a short real-world scenario?
- Can you name the most direct defense or control?
- Can you distinguish it from the closest similar concept?

2. Information gathering

Source lecture: CyberBasicsII

Core idea

Information gathering is the attacker's preparation phase. The lecture separates passive collection, where the attacker does not directly touch the target system, from active collection, where the attacker interacts with the target.

What you must know

- Passive information gathering includes search engines, social media, public documents, DNS data, leaked credentials, GitHub, LinkedIn, and OSINT databases.
- Active information gathering includes scanning, probing, service enumeration, banner grabbing, and direct requests to target infrastructure.
- OSINT can expose individuals and companies through posts, images, metadata, tickets, badges, public repositories, job ads, and leaked documents.
- Google dorking uses advanced search operators to find indexed information that should not be public.
- Subdomain enumeration maps names such as dev.example.com, vpn.example.com, admin.example.com.
- Service enumeration identifies open ports, services, and versions, which can lead to vulnerability research.

Hard parts explained

Passive vs active recon: Passive recon is quieter because the target usually does not see direct traffic from the attacker. Active recon is richer but easier to log and detect.

Google dorking: This is not magic hacking. It is clever searching. The problem is often bad publishing, misconfiguration, or search-engine indexing.

Magyar magyarázat

Passzív információgyűjtésnél a támadó nem kopogtat be közvetlenül a célrendszerhez. Aktívnál igen. Vizsgán ha port scan, banner grabbing vagy service scan szerepel, az aktív. Ha LinkedIn, Google, social media, leaked database vagy EXIF adat, az passzív/OSINT.

Exam traps and recognition cues

- Strava-style examples show that harmless-looking public data can reveal sensitive patterns.
- A badge or QR code photo can leak access information.
- Company job ads may reveal technologies used internally.
- Defensive answer: reduce public exposure, train staff, review metadata, harden services, monitor scanning.

Checkpoint questions

- Can you recognize this concept from a short real-world scenario?
- Can you name the most direct defense or control?
- Can you distinguish it from the closest similar concept?

3. Social engineering

Source lecture: CyberBasicsIII

Core idea

Social engineering exploits people rather than only software. The attacker abuses trust, urgency, fear, authority, curiosity, helpfulness, or routine to make the victim perform an unsafe action.

What you must know

- Phishing uses deceptive messages to steal credentials, deliver malware, or trigger payments.
- Spear phishing is targeted; whaling targets executives or high-value people.
- Pretexting builds a false story or identity, such as pretending to be IT support.
- Baiting uses tempting objects or files, such as a USB drive or a "salary list".
- Tailgating and piggybacking abuse physical entry processes.
- ClickFix tricks users into running a "fix" command or action themselves.
- Security awareness works only if reporting is easy and users are not punished for honest reporting.

Hard parts explained

Psychological triggers: Urgency reduces critical thinking. Authority makes people obey. Curiosity makes them click. Fear makes them rush. These are the real vulnerabilities.

HTTPS trap: A phishing page can have HTTPS. TLS protects the connection to that site; it does not prove the site is honest.

Magyar magyarázat

A social engineering nem azt jelenti, hogy a felhasználó "butaságot csinál". A támadó direkt olyan helyzetet épít, ahol az ember siet, fél, segíteni akar vagy tekintélyt követ. Ezért a védekezés nem csak oktatás, hanem jó folyamat: MFA, visszaellenőrzés, könnyű jelentés, gyanús kérések lassítása.

Exam traps and recognition cues

- "Your account will be locked in 24 hours" is urgency.
- "CEO asks for urgent transfer" is authority/whaling/business email compromise style.
- USB drive in parking lot is baiting.
- Following someone through a secure door is tailgating.

Checkpoint questions

- Can you recognize this concept from a short real-world scenario?
- Can you name the most direct defense or control?
- Can you distinguish it from the closest similar concept?

4. Physical security

Source lecture: CyberBasicsIV

Core idea

Physical security protects rooms, devices, network ports, printed information, badges, servers, and people. Digital security can fail if physical access is uncontrolled.

What you must know

- A laptop, USB port, badge, printer tray, whiteboard, or unlocked screen can become a cyber risk.
- Physical attacks often start with reconnaissance and social engineering before entry.
- Clean desk policy, screen locking, device encryption, visitor control, cameras, locks, and access badges are practical controls.
- Shoulder surfing, dumpster diving, badge cloning, unattended devices, and rogue network devices are examples of physical threats.
- Physical security supports confidentiality, integrity, and availability.

Hard parts explained

Defense in depth: Use several independent layers: locked doors, monitored areas, access logs, encrypted devices, least privilege, and trained employees.

Physical-digital bridge: A person with physical access can plug in a malicious device, steal a laptop, photograph notes, reset equipment, or connect to an internal network port.

Magyar magyarázat

Ha valaki fizikailag hozzáfér egy géphez vagy hálózati ponthoz, sok digitális védelem gyengül. Ezért számít a képernyőzár, a vendégkísérés, a szerverhelyiség zárása és a titkosított háttértár. Nem "irodai szabályoskodás", hanem valódi kiberbiztonság.

Exam traps and recognition cues

- Tailgating is both social engineering and physical security.
- Device encryption protects data when a laptop is stolen.
- A locked door is preventive; CCTV is mostly detective; backups can be corrective for loss.

Checkpoint questions

- Can you recognize this concept from a short real-world scenario?
- Can you name the most direct defense or control?
- Can you distinguish it from the closest similar concept?

5. Network security

Source lecture: CyberBasicsV

Core idea

Network security protects communication, services, segmentation, and monitoring. The key exam skill is matching a network problem to the correct control: firewall, VPN, IDS/IPS, SIEM, segmentation, encryption, or Zero Trust.

What you must know

- Ports identify services; open services are part of the attack surface.
- Transport encryption, such as TLS, protects data in transit from eavesdropping and tampering.
- Firewalls filter traffic using rules based on IP, port, protocol, direction, and sometimes application context.
- Network segmentation limits lateral movement after one device is compromised.
- VPN creates an encrypted tunnel but does not make users or endpoints safe by itself.
- IDS detects suspicious activity; IPS can block it.
- SIEM collects and correlates logs for detection, investigation, and alerting.
- Zero Trust means no automatic trust just because something is inside the network.

Hard parts explained

LAN/MAN/WAN: LAN is local, MAN is city/metropolitan scale, WAN spans large distances. The Internet is the most obvious WAN example.

TTL: Time To Live limits how many hops a packet can survive. It is useful in networking and can sometimes provide clues during reconnaissance, but it is not a perfect fingerprint.

Segmentation: Think of watertight doors in a ship. One flooded compartment should not sink everything.

Magyar magyarázat

A VPN gyakori csapda. A VPN titkosított alagút, de ha a felhasználó phishing oldalon megadja a jelszavát, vagy a laptopja fertőzött, a VPN nem menti meg. A VPN egy kontroll, nem teljes biztonság.

Exam traps and recognition cues

- Firewall allows or blocks traffic; it does not fix vulnerable code.
- IDS = detect. IPS = prevent/block.
- Segmentation is the answer when the problem is lateral movement.
- SIEM is the answer when logs need correlation and alerting.
- Zero Trust is continuous verification and least privilege, not "trust the internal network".

Checkpoint questions

- Can you recognize this concept from a short real-world scenario?
- Can you name the most direct defense or control?
- Can you distinguish it from the closest similar concept?

6. Web application security

Source lecture: CyberBasicsVI

Core idea

Web applications are exposed, input-driven, and often connected to databases. Most important risks come from broken access control, injection, XSS, insecure design, misconfiguration, and unsafe handling of user input.

What you must know

- OWASP Top 10 is a common reference list for major web application security risks.
- Default credentials are dangerous because attackers try them first.
- Insecure design means the workflow itself is unsafe, not merely a coding typo.
- Broken access control lets a user access data or functions they should not have.
- SQL injection manipulates database queries through unsafe input handling.
- XSS injects client-side code that runs in another user's browser.
- Directory traversal manipulates file paths to access unintended files.
- Input validation helps, but output encoding and parameterized queries are the stronger specific defenses for XSS and SQL injection.

Hard parts explained

SQL injection: Unsafe code builds SQL by concatenating user input. The fix is parameterized queries/prepared statements, where input is treated as data, not executable SQL.

XSS: The attacker's script runs in the victim's browser. Stored XSS is saved on the server; reflected XSS comes back immediately; DOM-based XSS happens in browser-side JavaScript.

Broken Access Control: If changing /user/123 to /user/124 shows another person's data, the server forgot to enforce authorization.

Magyar magyarázat

SQL injection és XSS közti különbség: SQLi az adatbázis felé támad, XSS a böngészőben futó kód felé. SQLi ellen prepared statement/parameterized query. XSS ellen output escaping/encoding és CSP. Ha a kérdés "database query", gondolj SQLi-re. Ha "victim browser executes script", gondolj XSS-re.

Exam traps and recognition cues

- Parameterized queries are the best direct answer for SQL injection.
- Output encoding/escaping is the best direct answer for XSS.
- Server-side authorization checks are the answer for broken access control.
- Allowlists and path normalization help against directory traversal.
- Changing default passwords is mandatory hardening.

Checkpoint questions

- Can you recognize this concept from a short real-world scenario?
- Can you name the most direct defense or control?
- Can you distinguish it from the closest similar concept?

7. Cryptographic fundamentals

Source lecture: CyberBasicsVII

Core idea

Cryptography protects information mathematically. The key exam skill is separating encoding, hashing, symmetric encryption, asymmetric encryption, digital signatures, and key exchange.

What you must know

- Security by obscurity is weak if secrecy of the method is the only protection. Strong cryptography assumes the algorithm may be known and the key remains secret.
- Classical ciphers such as Caesar, ROT13, substitution, Scytale, and Vigenere are useful for history and concepts, not modern security.
- Frequency analysis breaks many simple substitution ciphers because natural languages have uneven letter frequencies.
- One-Time Pad can be perfectly secure only if the key is truly random, as long as the message, used once, and kept secret.
- Symmetric encryption uses the same secret key for encryption and decryption. AES is the key modern example.
- Asymmetric cryptography uses a public/private key pair. RSA is a key example.
- Diffie-Hellman allows two parties to establish a shared secret over an insecure channel.
- Digital signatures support authenticity, integrity, and non-repudiation.

Hard parts explained

Confusion and diffusion: Confusion hides the relationship between key and ciphertext. Diffusion spreads plaintext changes widely through the ciphertext.

Symmetric vs asymmetric: Symmetric is fast but has key-sharing problems. Asymmetric helps with key exchange and signatures but is slower.

RSA intuition: RSA relies on mathematical difficulty, especially factoring large numbers in classic RSA assumptions. It is not secure because the algorithm is secret.

Magyar magyarázat

A kriptónál a legfontosabb vizsgacsapda: encoding != encryption != hashing. Encoding csak átalakítás, nem védelem. Encryption kulccsal visszafejthető. Hash normál esetben nem visszafejthető, hanem lenyomat. Digitális aláírás pedig nem titkosítás, hanem hitelesség/integritás bizonyítása.

Exam traps and recognition cues

- ROT13 is not secure encryption.
- AES is symmetric. RSA is asymmetric. Diffie-Hellman is key exchange.
- One-Time Pad fails if the key is reused or predictable.
- Digital signature helps prove origin and detect modification.

Checkpoint questions

- Can you recognize this concept from a short real-world scenario?
- Can you name the most direct defense or control?
- Can you distinguish it from the closest similar concept?

8. Password management and hashes

Source lecture: CyberBasicsVIII

Core idea

Password security combines human behavior, storage design, cracking resistance, and authentication controls. Hashing is central, but hashing alone is not enough if it is fast, unsalted, or based on weak algorithms.

What you must know

- Good passwords are long, unique, and hard to guess. Password managers help generate and store them.
- Password reuse turns one breach into many account compromises.
- Plaintext password storage is a severe design failure.
- A cryptographic hash maps input to a fixed-size output and should be one-way and collision-resistant.
- Salting adds unique random data so identical passwords do not produce identical stored hashes.
- Slow password hashing algorithms make cracking more expensive.
- MD5 and SHA-1 are historically important but not safe for modern collision-resistant security use.
- Birthday attacks explain why collisions appear sooner than simple intuition suggests.
- MFA reduces damage when a password is stolen, though it does not fix every authentication problem.

Hard parts explained

Hash vs encryption: Encryption is reversible with a key. Hashing is not intended to be reversed. Password cracking tries guesses until one hash matches.

Avalanche effect: A tiny input change should cause a very different hash output.

Dictionary and brute-force attacks: Dictionary attacks try likely passwords. Brute force tries many combinations. GPUs make fast hashes easier to crack.

Magyar magyarázat

A jelszót nem "titkosítva" kell tárolni klasszikus értelemben, hanem sózott, lassú jelszóhash-sel. Ha az adatbázis kiszivárog, a támadó nem tudja rögtön a jelszavakat, hanem próbálgatnia kell. A só megakadályozza, hogy ugyanaz a jelszó mindenkinél ugyanazt a hasht adjon.

Exam traps and recognition cues

- Hashing is one-way; cracking is guessing, not decrypting.
- Salt defeats simple rainbow-table reuse and identical-hash visibility.
- Long passphrases are usually better than short complex-looking passwords.
- MFA is a strong control against stolen passwords.

Checkpoint questions

- Can you recognize this concept from a short real-world scenario?
- Can you name the most direct defense or control?
- Can you distinguish it from the closest similar concept?

9. Mobile and embedded / IoT security

Source lecture: CyberBasicsIXA + IXB

Core idea

Mobile and embedded devices expand the attack surface because they contain sensors, credentials, personal data, network access, and often weak update or permission models. IoT/embedded security is hard because devices are cheap, long-lived, physically accessible, and inconsistently patched.

What you must know

- Mobile threats include malicious apps, spyware, banking malware, smishing, excessive permissions, unsafe Wi-Fi, lost devices, and supply-chain risks.
- Permissions matter because apps may access camera, microphone, location, contacts, files, SMS, or accessibility features.
- Secure boot helps ensure the device starts trusted software.
- Encrypted storage protects data when the device is lost or stolen.
- Mobile VPN helps on untrusted networks but does not stop malicious apps or phishing.
- IoT threats include default credentials, exposed services, missing updates, weak authentication, unencrypted traffic, and poor component management.
- Secure by design means security must be built into the product lifecycle, not added after release.

Hard parts explained

Mobile malware examples: Cases such as Cabir, FluBot, Pegasus, SparkCat, and DarkSword illustrate that mobile threats range from simple worms to advanced spyware and data-stealing apps.

Embedded constraints: Small devices may have limited CPU, memory, UI, and update capability. That makes classic desktop-style security harder.

IoT botnets: One weak camera is bad. Thousands of weak cameras can become a DDoS botnet.

Magyar magyarázat

Mobilon és IoT-n a legnagyobb gond, hogy az eszköz egyszerre személyes, hálózati és fizikai objektum. Egy telefonban ott vannak a tokenek, üzenetek, banki appok, lokáció. Egy IoT kamera pedig gyenge jelszóval botnet része lehet. A frissítés és az alapértelmezett jelszó kritikus.

Exam traps and recognition cues

- Android permissions/manifest-style examples point to mobile app security.
- Default credentials and no firmware update point to IoT risk.
- Secure boot protects boot integrity; storage encryption protects data at rest.
- VPN is not a cure-all on mobile either.

Checkpoint questions

- Can you recognize this concept from a short real-world scenario?
- Can you name the most direct defense or control?
- Can you distinguish it from the closest similar concept?

10. Malware and anti-virus

Source lecture: CyberBasicsX

Core idea

Malware is malicious software designed to damage systems, steal data, spy, extort, persist, or provide unauthorized access. Anti-virus and endpoint protection use several detection strategies, each with limitations.

What you must know

- A virus attaches to host files or programs and spreads when they run.
- A worm spreads independently, often over networks.
- A trojan pretends to be legitimate or useful while hiding malicious behavior.
- Ransomware encrypts or locks data and demands payment.
- Spyware collects information from the victim.
- Rootkits hide presence and maintain privileged access.
- RATs provide remote access to a compromised system.
- Infection vectors include social engineering, removable drives, unverified downloads, vulnerable services, and weak configurations.
- AV detection can be signature-based, heuristic, behavior-based, sandbox-based, intelligence-driven, or ML-assisted.

Hard parts explained

Signature vs behavior: Signature detection matches known malware patterns. Behavior detection watches suspicious actions. New or obfuscated malware can evade simple signatures.

Sandbox evasion: Malware may detect virtual/sandbox environments and behave harmlessly until it reaches a real victim.

VirusTotal caution: Uploading sensitive internal files to public scanning services can leak data.

Magyar magyarázat

Malware típusoknál a terjedés módja számít. Vírus: más fájlhoz kapcsolódik. Worm: önállóan terjed. Trojan: jónak álcázza magát. Ransomware: zsarol. Rootkit: elrejt és hozzáférést tart fenn. RAT: távoli vezérlést ad.

Exam traps and recognition cues

- CIH/Chernobyl is a virus example.
- ILOVEYOU is a worm example.
- WannaCry is ransomware with worm-like spreading behavior through SMB exploit use.
- False positives and false negatives are unavoidable detection tradeoffs.

Checkpoint questions

- Can you recognize this concept from a short real-world scenario?
- Can you name the most direct defense or control?
- Can you distinguish it from the closest similar concept?

11. Software security

Source lecture: CyberBasicsXI

Core idea

Software security is about building and operating applications that resist unauthorized access, misuse, and vulnerabilities. The exam strongly cares about CVE vs CWE and testing methods: SAST, DAST, IAST, penetration testing, and fuzzing.

What you must know

- Software safety is about preventing harm from software behavior; software security focuses on malicious or unauthorized actions.
- Common weaknesses include buffer overflows, XSS, CSRF, insecure deserialization, broken access control, and improper input validation.
- CWE describes a weakness type or category. CVE identifies a specific known vulnerability in a specific product/component.
- SAST analyzes code without running it.
- DAST tests a running application from the outside.
- IAST combines runtime observation with internal application context.
- Penetration testing is human-driven attack simulation.
- Fuzzing sends many generated or mutated inputs to find crashes and edge-case bugs.
- Secure SDLC integrates security from requirements and design to coding, testing, deployment, monitoring, and patching.

Hard parts explained

CWE vs CVE: CWE is the kind of mistake. CVE is the named real-world instance. Example: out-of-bounds write is a CWE category; a specific vulnerable product version gets a CVE.

CWE-787: Out-of-bounds write: the program writes outside the intended memory area. This can cause crash, corruption, or code execution.

Dependency risk: Log4Shell and Heartbleed show that libraries can become critical attack surfaces.

Magyar magyarázat

SAST/DAST keverésre figyelj. SAST: forráskódot néz futtatás nélkül, korán jó, de lehet sok false positive. DAST: futó alkalmazást támad kívülről, látja a valós viselkedést, de nem mindig mondja meg pontosan a kódban az okot. IAST a kettő közti hibrid.

Exam traps and recognition cues

- CWE = category/type of weakness. CVE = specific vulnerability identifier.
- Fuzzing is excellent for parsers and memory bugs.
- Secure SDLC means security is not only final testing.
- Log4Shell = dependency/logging library risk. Heartbleed = crypto library memory disclosure. Dirty COW = Linux privilege escalation.

Checkpoint questions

- Can you recognize this concept from a short real-world scenario?
- Can you name the most direct defense or control?
- Can you distinguish it from the closest similar concept?

12. AI in cybersecurity

Source lecture: CyberBasicsXII

Core idea

AI is both a defensive tool and an offensive amplifier. The lecture covers AI/LLM basics, defensive use cases, offensive misuse, and the secure use of AI systems.

What you must know

- AI systems use algorithms and data to perform tasks such as classification, pattern recognition, language generation, and decision support.
- LLM means Large Language Model; GPT means Generative Pretrained Transformer.
- LLM generation involves tokenization, encoding, prediction, and detokenization.
- Defensive AI can support anomaly detection, log analysis, phishing detection, malware classification, SAST triage, playbook generation, and alert triage.
- Offensive AI can scale phishing, impersonation, deepfakes, malware variation, vulnerability discovery, and reconnaissance.
- Secure AI use requires good data quality, secure hosting, safe data handling, controlled tool access, evaluation, monitoring, and resilience against prompt injection.
- LLM risks include hallucination, sensitive data leakage, insecure code generation, dependency hallucination, and overtrust.

Hard parts explained

Prompt injection: An attacker places instructions in user input or external content to override the intended system behavior of an AI tool.

Hallucination: The model can produce confident but wrong answers. In security, confident wrong answers are dangerous.

AI as amplifier: AI does not magically replace expertise. It makes both good workflows and bad attacks faster.

Magyar magyarázat

AI-nál ne az legyen a fejedben, hogy "jó" vagy "rossz". Ugyanaz a technológia segíthet logelemzésben és phishing email írásában is. A vizsgán valószínűleg azt kell felismerni, hogy egy példa defensive use, offensive use vagy AI-specific risk, például prompt injection/hallucination/data leakage.

Exam traps and recognition cues

- Threat detection and alert triage are defensive AI examples.
- Realistic phishing, deepfakes, and malware evasion are offensive AI examples.
- Prompt injection matters most when AI reads untrusted content or controls tools.
- Do not paste secrets into public AI tools.

Checkpoint questions

- Can you recognize this concept from a short real-world scenario?
- Can you name the most direct defense or control?
- Can you distinguish it from the closest similar concept?

Final exam review sheets

Must-not-confuse table

Term	Meaning	Exam angle
Authentication	Proves identity: password, biometric, token, MFA.	Question asks: who is the user?
Authorization	Controls permitted actions after identity is known.	Question asks: what can the user access/do?
Accounting	Logs actions for audit and investigation.	Question mentions logs, traceability, audit.
Hashing	One-way fingerprint. Used for integrity and password storage.	Not reversible; cracking means guessing.
Encryption	Reversible with a key. Protects confidentiality.	If decrypting is needed, it is encryption, not hashing.
Encoding	Format conversion, not security.	Base64 is not encryption.
CVE	Specific vulnerability identifier.	Concrete product/version vulnerability.
CWE	Weakness category/type.	Class of mistakes such as out-of-bounds write.
IDS	Detects suspicious activity.	Raises alert.
IPS	Can block suspicious activity.	Prevention/blocking.
SQL Injection	Database query manipulation.	Prepared statements/parameterized queries.
XSS	Script runs in victim browser.	Output encoding/CSP.
Passive Recon	No direct interaction with target system.	OSINT, Google, social media, leaks.
Active Recon	Direct probing of target.	Port scan, service enumeration.
Virus	Needs host file/program.	Spreads by infected files.
Worm	Self-spreads over networks.	Can spread without user opening every copy.
VPN	Encrypted tunnel.	Not protection against phishing or malware by itself.
HTTPS	Encrypted connection to a site.	Does not prove the site is legitimate.

Attack -> best direct defense

Term	Meaning	Exam angle
Phishing / stolen password	MFA, awareness, reporting, domain checks, safe processes	Human manipulation + credential theft.
SQL Injection	Parameterized queries / prepared statements	Input must not become SQL code.
XSS	Output escaping/encoding, CSP, safe frameworks	Script must not execute in victim browser.
Broken Access Control	Server-side authorization checks for every sensitive action	Never trust URL/user-controlled IDs.
Directory Traversal	Allowlist paths, normalize paths, restrict file permissions	Do not let ../ reach sensitive files.
Lateral movement	Network segmentation, least privilege, monitoring	Limit blast radius.
Unknown malware	Behavior detection, sandboxing, EDR, least privilege, patching	Signatures alone may fail.
Lost laptop	Full disk encryption, screen lock, remote wipe, backups	Data at rest risk.
Public information leakage	OSINT review, metadata stripping, staff training	Reduce reconnaissance value.
Weak IoT devices	Change default credentials, update firmware, segment network	Embedded devices are long-lived and exposed.

One-page memory map

- CIA: Confidentiality = no unauthorized reading; Integrity = no unauthorized changing; Availability = accessible when needed.
- AAA: Authentication = identity; Authorization = permission; Accounting = logs.
- Risk: threat actor exploits vulnerability causing impact.
- Recon: passive is quiet OSINT; active touches the target.
- Social engineering: attack the human process with urgency, authority, fear, curiosity, trust.
- Network: firewall filters; VPN tunnels; IDS detects; IPS blocks; SIEM correlates logs; segmentation limits spread.
- Web: SQLi attacks database queries; XSS attacks browsers; broken access control attacks authorization logic.
- Crypto: AES symmetric; RSA asymmetric; DH key exchange; signature proves origin/integrity; hash is one-way.
- Passwords: long + unique + manager + MFA; store salted slow hashes, never plaintext.
- Mobile/IoT: permissions, updates, secure boot, encrypted storage, default credentials, exposed services.
- Malware: virus attaches, worm self-spreads, trojan disguises, ransomware extorts, spyware watches, rootkit hides.
- Software: CWE type, CVE instance; SAST code, DAST running app, IAST hybrid, fuzzing weird inputs.
- AI: defensive detection vs offensive scaling; prompt injection, hallucination, data leakage, overtrust.

Fast study plan

1. Day 1: Learn CIA, AAA, risk, controls, and information gathering. Make sure passive vs active is automatic.
2. Day 2: Learn social engineering, physical security, and network controls. Drill IDS/IPS/SIEM/VPN/firewall differences.
3. Day 3: Learn web attacks. SQLi, XSS, broken access control, directory traversal must be instant-recognition topics.
4. Day 4: Learn crypto and passwords. Drill hash vs encryption, symmetric vs asymmetric, salt, MFA, password cracking.
5. Day 5: Learn mobile/IoT, malware, software security, and AI. Focus on definitions and examples.
6. Final hour before exam: read the must-not-confuse table and attack-defense table only. Do not start new deep topics.

Last warning

Do not memorize this as a wall of text. The exam is multiple choice, so your job is pattern recognition.

For every topic, ask three things:

1. What is being attacked?
2. What security property breaks?
3. What control would reduce the risk?

Source PDFs used

- CyberSec-Basics_Exam_guide.pdf
- CyberBasics0.pdf
- CyberBasicsI.pdf
- CyberBasicsII.pdf
- CyberBasicsIII.pdf
- CyberBasicsIV.pdf
- CyberBasicsV.pdf
- CyberBasicsVI.pdf
- CyberBasicsVII.pdf
- CyberBasicsVIII.pdf
- CyberBasicsIXA.pdf
- CyberBasicsIXB.pdf
- CyberBasicsX.pdf
- CyberBasicsXI.pdf
- CyberBasicsXII.pdf